

Security Operation

Analisi architetturale, prevenzione e risposta agli incidenti su piattaforma e-commerce

Samuele Asaro

Epicode

Introduzione

In questo report analizziamo l'architettura di rete di una piattaforma di e-commerce esposta su Internet, individuando le contromisure da adottare di fronte a quattro scenari: attacchi applicativi (SQLi/XSS), un attacco DDoS, un'infezione da malware e, infine, una revisione strutturale più ampia dell'infrastruttura.

Come vedremo, non serve reinventare l'architettura da zero: la combinazione di controlli mirati su un'unica regola di firewall troppo permissiva, di pratiche di secure coding e di una strategia di segmentazione e monitoraggio è sufficiente a coprire tutti gli scenari richiesti.

Scopo del progetto

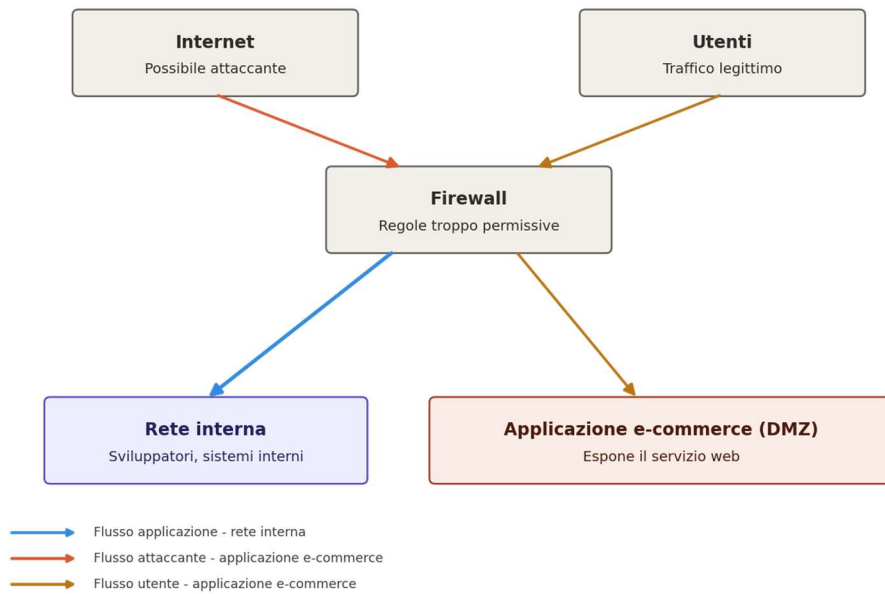
In riferimento all'architettura di rete di partenza, l'obiettivo del progetto è sviluppare le seguenti azioni:

- Azioni preventive: modificare l'architettura per difendere l'applicazione Web da attacchi di tipo SQLi e XSS da parte di un attaccante.
- Impatti sul business: l'applicazione Web subisce un attacco di tipo DDoS dall'esterno che la rende non raggiungibile per 10 minuti; calcolare l'impatto sul business considerando che in media ogni minuto gli utenti spendono 1.500 EUR sulla piattaforma.
- Response: l'applicazione Web viene infettata da un malware; la priorità è non far propagare il malware sulla rete interna, senza rimuovere l'accesso dell'attaccante alla macchina infettata.
- Soluzione completa: unire le contromisure delle azioni preventive e della response in un'unica architettura.
- Modifica più aggressiva: valutare un'evoluzione strutturale dell'infrastruttura secondo un approccio Zero Trust.

Contesto: l'architettura di partenza

Applicazione e-commerce esposta su Internet, con un firewall centrale che media il traffico tra Internet, gli utenti, l'applicazione in DMZ e la rete interna.

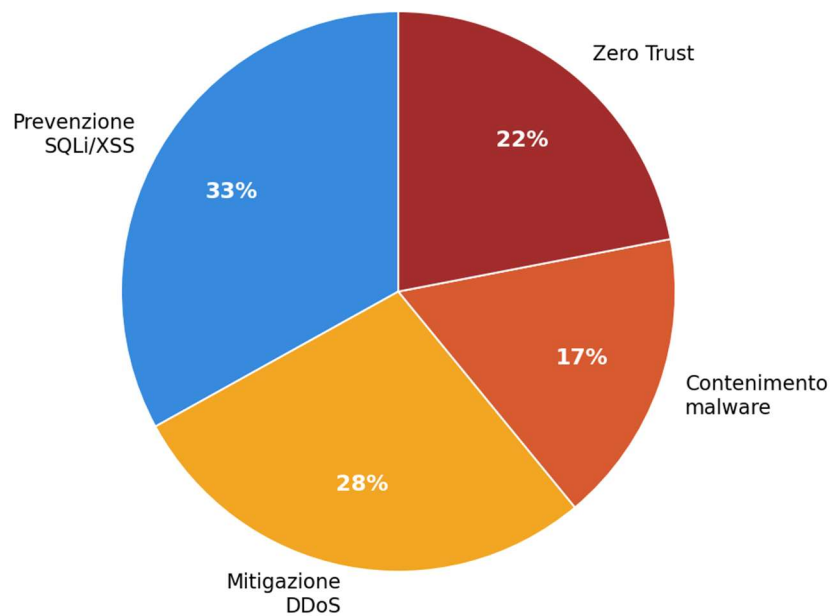
Criticità individuata: la rete interna è raggiungibile dalla DMZ per via delle policy sul firewall. Se il server in DMZ viene compromesso, un attaccante potrebbe potenzialmente raggiungere la rete interna.



Distribuzione delle contromisure proposte

Prima di entrare nel dettaglio di ogni scenario, un riepilogo grafico delle contromisure individuate, suddivise per area di intervento.

Distribuzione delle contromisure per area



Azioni preventive

SQL Injection e XSS nascono da input dell'utente non controllato: nella SQLi l'input finisce dentro una query e la altera, nella XSS viene mostrato ad altri utenti ed eseguito come codice nel browser.

Le contromisure principali sono:

Query parametrizzate: l'input dell'utente non viene mai unito direttamente al testo della query SQL, quindi non può modificarla.

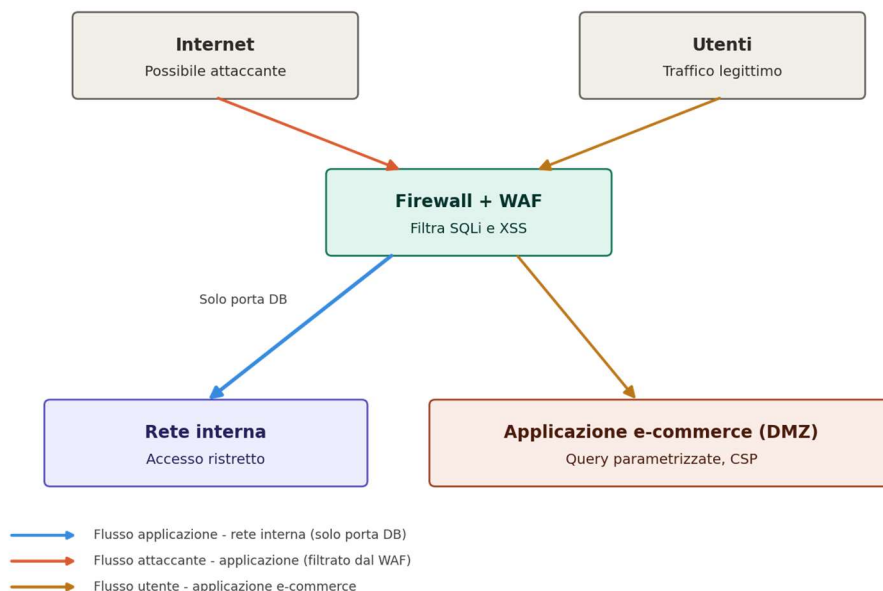
Content Security Policy (CSP): un'impostazione del sito che limita quali script il browser può eseguire, bloccando gli attacchi XSS.

WAF (Web Application Firewall): integrato al firewall, riconosce e blocca i tentativi di SQLi e XSS prima che arrivino all'applicazione.

Input validation lato server: si accettano solo i formati previsti, non tutto ciò che arriva.

Least privilege sull'utente database: l'account usato dall'applicazione non ha permessi di amministrazione.

Restrizione della regola di firewall: la DMZ può raggiungere solo la porta del database, non l'intera rete interna.



Impatti sul business

Un attacco DDoS rende l'applicazione irraggiungibile per 10 minuti. Con una spesa media di 1.500 EUR al minuto, la perdita diretta è:

10 minuti x 1.500 EUR al minuto = 15.000 EUR di mancati ricavi.

Un DDoS usa un gran numero di dispositivi compromessi (una botnet) per sovraccaricare il sistema e renderlo non disponibile agli utenti.

A questa cifra si aggiungono danno reputazionale, possibili penali verso partner, costi di gestione dell'incidente e utenti che abbandonano il sito.

Azioni preventive:

- Servizio anti-DDoS / CDN (es. Cloudflare, AWS Shield) che assorbe il traffico malevolo

- Rate limiting sulle richieste in ingresso
- Load balancer con auto-scaling per i picchi di traffico
- Ridondanza multi-region
- Piano di incident response con soglie di allerta

Response

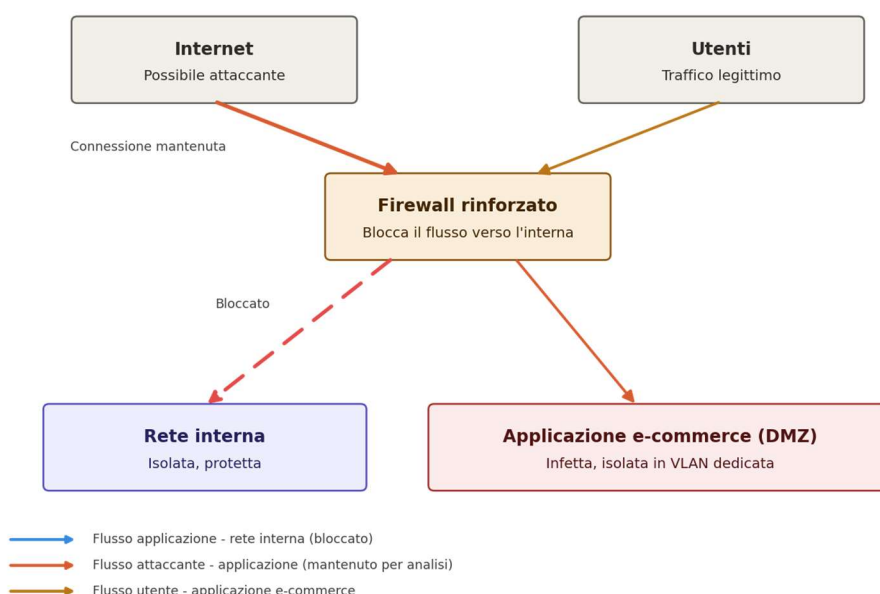
L'applicazione viene infettata da un malware. La priorità è impedire che si propaghi sulla rete interna, senza rimuovere l'accesso dell'attaccante alla macchina infettata: la connessione resta attiva per osservarne il comportamento.

Non blocchiamo del tutto la macchina infettata anche per un motivo economico: significherebbe bloccare l'intero e-commerce, con un danno maggiore di quello che vogliamo evitare.

Blocco della regola di firewall verso la rete interna: impedisce ogni movimento laterale verso i sistemi interni, mentre il collegamento verso Internet resta attivo.

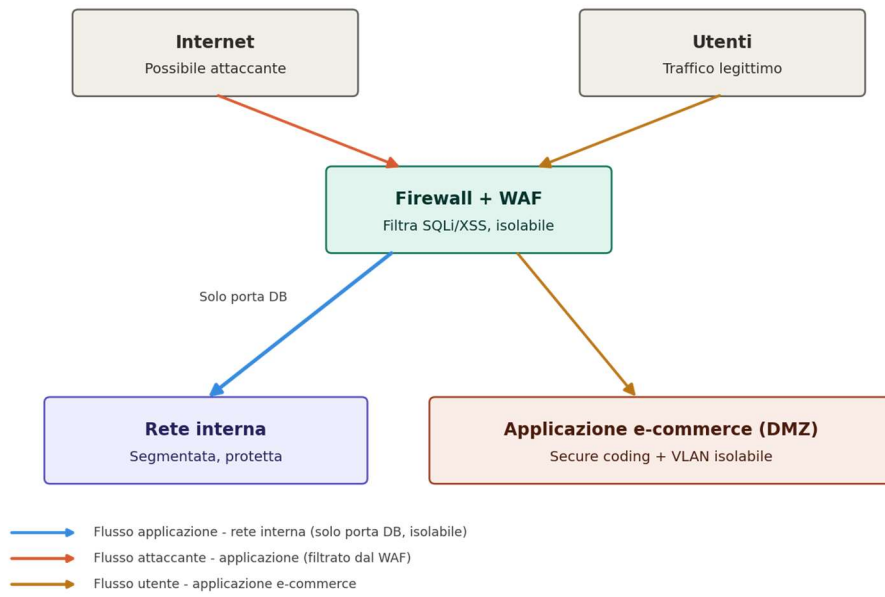
Isolamento in VLAN dedicata: il server infetto viene spostato in un segmento separato senza interrompere la sua raggiungibilità da Internet.

Monitoraggio attivo (EDR/SIEM): osserva il traffico verso l'attaccante per raccogliere informazioni utili.



Soluzione completa

Uniamo le misure delle azioni preventive e della response in un'unica architettura, pronta sia a prevenire gli attacchi applicativi sia a isolare rapidamente una compromissione senza dover riprogettare nulla durante un incidente reale.



Architettura combinata: Firewall + WAF in ingresso, regola minima e isolabile verso la rete interna

Modifica piu aggressiva

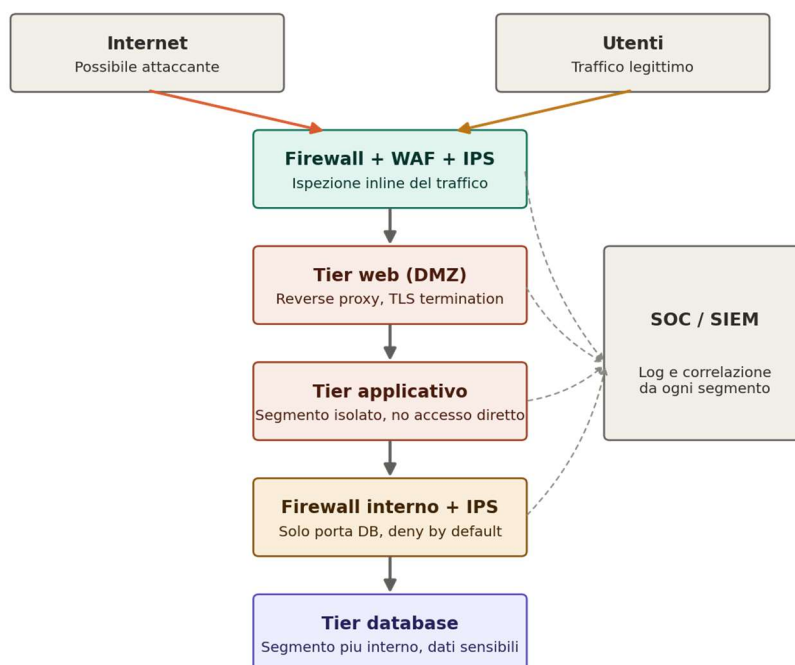
Le soluzioni precedenti risolvono le criticita puntuali della traccia. Una modifica piu aggressiva ripensa l'intera architettura secondo un approccio Zero Trust, sostituendo la singola DMZ con una segmentazione a tre livelli, ciascuno isolato e monitorato, ed eliminando ogni fiducia implicita tra i segmenti.

Segmentazione a tre livelli (web / application / database): il tier web espone solo il reverse proxy, il tier applicativo non e mai raggiungibile direttamente da Internet, il tier database riceve connessioni solo dal tier applicativo.

Firewall e IPS inline tra ogni livello: policy deny-by-default anche tra i segmenti interni, non solo al perimetro.

Zero Trust: ogni passaggio tra segmenti richiede autenticazione e autorizzazione esplicita (es. mutual TLS).

SOC con SIEM centralizzato: correla i log di ogni segmento per rilevare rapidamente movimenti laterali.



Zero Trust: ogni passaggio tra segmenti richiede autenticazione e autorizzazione esplicita, nessuna fiducia implicita tra i livelli.

Architettura Zero Trust a tre livelli con IPS inline e SOC/SIEM centralizzato

Rispetto alla soluzione completa, qui la superficie di attacco si riduce ulteriormente: anche in caso di compromissione del tier web, l'attaccante non ha comunque visibilita diretta sul database ne sulla rete interna, e ogni suo movimento genera eventi che il SIEM puo correlare in tempo reale. Il costo e una maggiore complessita operativa, da valutare in base al rischio accettabile dall'organizzazione.

Riepilogo delle Contromisure

#	Contromisura	Area
1	WAF che filtra pattern SQLi/XSS a livello di rete	Prevenzione
2	Query parametrizzate e output encoding + CSP lato applicativo	Prevenzione
3	Restrizione della regola di firewall alla sola porta del database	Prevenzione
4	Servizio anti-DDoS/CDN e rate limiting	Mitigazione DDoS
5	Load balancer con auto-scaling e ridondanza multi-region	Mitigazione DDoS
6	Isolamento del server infetto in VLAN dedicata	Contenimento malware
7	Blocco della regola di firewall verso la rete interna	Contenimento malware
8	Monitoraggio EDR/SIEM del traffico C2 in uscita	Contenimento malware
9	Segmentazione a tre livelli web/application/database	Zero Trust
10	SOC con SIEM centralizzato per la correlazione degli eventi	Zero Trust

Conclusioni

Questo esercizio dimostra un principio fondamentale della sicurezza delle applicazioni Web: la maggior parte dei rischi analizzati origina da un'unica causa strutturale, una regola di firewall troppo permissiva tra DMZ e rete interna, piuttosto che da vulnerabilità isolate e complesse da individuare.

Le raccomandazioni principali che emergono da questa analisi sono:

- Applicare query parametrizzate e CSP come difesa di base contro SQLi e XSS
- Dimensionare il calcolo dell'impatto economico includendo sempre i costi indiretti, non solo la perdita diretta
- In risposta a un incidente, distinguere sempre tra contenimento (bloccare la propagazione) ed eradicazione (rimuovere l'accesso), applicandoli nell'ordine corretto
- Valutare nel tempo un'evoluzione verso un'architettura Zero Trust, che riduce strutturalmente la superficie di attacco